

Criação de Plugin para Navegador Web Firefox para Detecção e Bloqueio de Rastreadores

Objetivo: Criação de extensão para o navegador Firefox para detecção de ataques e violação de privacidade no cliente web, com validação da ferramenta em páginas de teste padronizadas e em sites reais.

Prazo: 1 semana a partir da divulgação.

Descrição: Desenvolver uma ferramenta capaz de detectar e apresentar:

- Conexões a domínios de terceira parte em uma navegação web;
- A quantidade de cookies injetados no carregamento de uma página, diferenciando primeira e terceira parte, sessão e persistentes;
- O armazenamento de dados no cliente por intermédio do HTML5 (localStorage, sessionStorage, IndexedDB);
- Sincronismo de cookies (cookie sync / bounce tracking);
- Canvas fingerprint;
- Potenciais ameaças de sequestro de navegador (hijacking e hook);
- Uma pontuação de privacidade da página, a partir de uma metodologia explícita.

A insegurança dos browsers

O navegador web, ou browser, é o processo que fica mais tempo em execução em um sistema operacional, seja por motivos pessoais ou profissionais. Além deste detalhe, os navegadores mais utilizados hoje são multiplataforma. Estas duas características chamam a atenção para que fraudadores busquem explorar vulnerabilidades de sistemas no elo mais fraco do ecossistema da tecnologia da informação: o usuário final.

Os browsers, quando foram lançados, exibiam apenas textos (ASCII e HTML) e imagens (GIF e JPEG). Devido às limitações da linguagem HTML (Hyper-Text Markup Language), logo surgiram alternativas para ampliar a capacidade do browser e torná-lo mais dinâmico e interativo. Uma das primeiras iniciativas neste sentido foi a adoção dos helpers (aplicativos auxiliares), que evoluíram para os atuais plug-ins¹.

Extensões de navegadores, ou plug-ins, são programas executáveis que permitem ao browser executar arquivos em formatos diferentes de HTML, como áudio, animações e acesso a banco de dados. Um de seus pontos fracos é que sua confiança e segurança estão depositadas em quem o desenvolveu. Como a extensão de navegador está

incorporada ao "core" do browser, ela utiliza o mesmo PID (Process ID), tendo assim acesso irrestrito ao sistema e comprometendo o ambiente.

Com a introdução de linguagens/tecnologias como Java, JavaScript, VBScript e ActiveX, o browser passou a receber código ativo pela rede, ou seja, o simples fato de visitar um site na Internet já é suficiente para receber um código malicioso que pode ter acesso a qualquer parte do sistema (processador, memória, discos e rede) e, até mesmo, desligar a estação².

Existem inúmeros motivos para uma aplicação client-server executar operações no lado cliente, como a necessidade de acesso a informações ou funcionalidades disponíveis na estação e não no servidor, ou para poupar poder de processamento no servidor.

Garantir a segurança em clientes web é muito mais complexo do que no web server. Essa complexidade se dá pela impossibilidade de os administradores do sistema gerenciarem de forma efetiva a segurança do dispositivo dos usuários.

Browser hijacking

É a modificação não autorizada das configurações de um browser por um código malicioso, com o objetivo de ter acesso aos recursos do sistema ou inserir anúncios indesejados. É muito comum que a instalação de plugins não confiáveis cause ações indesejadas pelo browser. Algumas são instaladas sem o consentimento do usuário.

Outra forma de sequestro de navegadores é por meio da exploração de uma falha de cross-site scripting (XSS) em uma aplicação web. A falha de XSS pode permitir que um invasor utilize, por exemplo, o framework BeEF para injetar um código JavaScript dentro de uma página web vulnerável. A partir de sua execução no navegador, o invasor poderá enviar comandos ao cliente infectado.

Entregáveis (obrigatórios para qualquer conceito)

1. **Repositório Git e plugin.** Repositório com histórico de commits incrementais ao longo da semana e o plugin instalável no Firefox (manifest.json + instruções de carregamento via about:debugging).
2. **Relatório de execução no DuckDuckGo Privacy Test Pages.** Tabela com: teste executado × resultado esperado (reportado pela própria página) × resultado do plugin × explicação de cada divergência. Cada linha deve ser acompanhada de print do plugin em execução na página.
3. **Análise de 3 sites reais.** Sites sorteados por matrícula a partir da lista divulgada pelo professor. Para cada site: arquivo HAR exportado do DevTools + comparação do que o plugin detectou com o relatório do Blacklight (The Markup) e com os bloqueios do uBlock Origin.
4. **Pontuação de privacidade.** Score aplicado aos 3 sites, com a metodologia descrita (critérios, pesos, justificativa) e comparada ao resultado do Blacklight.

Conceito C (Nota C)

- Plugin instala e roda no Firefox sem erro;
- Detecta e apresenta: conexões a domínios de terceira parte, contagem de cookies injetados e uso de armazenamento local (HTML5);
- Relatório do DDG Privacy Test Pages cobrindo, no mínimo, as páginas de Tracker Reporting, Storage blocking e Fingerprinting/canvas;
- HAR dos 3 sites reais entregue.

Conceito B (Nota B)

Tudo do Conceito C, mais:

- Diferencia cookies de primeira e terceira parte, e de sessão e persistentes;
- Detecta canvas fingerprint e bounce tracking / cookie sync (páginas de Bounce tracking e Query parameters do DDG);
- Relatório do DDG cobre também Tracker Blocking e Storage partitioning, com explicação técnica de cada divergência entre o esperado e o que o plugin observou;
- Reconciliação nos 3 sites reais: cada rastreador que o Blacklight ou o uBlock Origin identificaram e o plugin não (ou vice-versa) tem uma explicação técnica.

Conceito A (Nota A)

Tudo do Conceito B, mais:

- Detecta indicadores de hijacking/hook (ex.: WebSocket ou polling persistente para domínio terceiro; script injetado que altera objetos globais; a página js-leaks do DDG serve de teste);
- Pontuação de privacidade com metodologia explícita (critérios, pesos, justificativa), aplicada aos 3 sites, com comparação crítica ao Blacklight: onde concordam, onde divergem e por quê;
- Interface do plugin exibe o relatório por página (rastreadores, cookies, storage, score) e permite lista de bloqueio personalizada.

Pontos de atenção

- Repositório com commit único ou com histórico concentrado no último dia: pode haver descontos na nota;
- Relatório sem arquivo HAR ou sem prints do plugin em execução: entregáveis 2 e 3 não pontuam;
- Explicações de divergência genéricas, sem referência ao tráfego observado no HAR ou na página de teste, não são consideradas.

Formato de entrega

- Link do repositório (público ou com acesso concedido ao professor);
- Relatório em PDF contendo os entregáveis 2, 3 e 4;
- Arquivos HAR e prints anexados ao repositório em pasta evidencias/.

Indicação para pesquisa

Desenvolvimento de extensões:

- https://developer.mozilla.org/pt-BR/docs/Mozilla/Add-ons/WebExtensions/sua_primeira_WebExtension
- <https://developer.mozilla.org/pt-BR/docs/Mozilla/Add-ons/WebExtensions>
- <https://github.com/Miraculix200/StoragErazor>
- <https://addons.mozilla.org/pt-BR/firefox/addon/clear-storage-button/>

Páginas de teste e ferramentas de referência:

- <https://github.com/duckduckgo/privacy-test-pages> (DuckDuckGo Privacy Test Pages)
- <https://themarkup.org/blacklight> (Blacklight, The Markup)
- <https://coveryourtracks.eff.org> (Cover Your Tracks, EFF)
- <https://browserleaks.com/canvas> (BrowserLeaks, canvas fingerprint)
- <https://fingerprintable.org>
- <https://github.com/gorhill/uBlock> (uBlock Origin)
- <https://github.com/jonasstrehle/supercookie> (demonstração de supercookie via favicon)

¹ http://www.training.com.br/lpmaia/pub_seg_browser.htm

² http://www.training.com.br/lpmaia/pub_seg_browser.htm